

INTERPRETACIÓN DE LA NORMA ISO/IEC 27001:2022



¿QUÉ ES UN SISTEMA DE GESTIÓN?

Un sistema de gestión es la forma en que la organización gestiona las partes interrelacionadas de su negocio para alcanzar sus objetivos. Estos objetivos pueden relacionarse con una serie de temas diferentes, incluyendo la calidad del producto o servicio, la eficiencia operativa, el rendimiento medioambiental, la salud y la seguridad en el lugar de trabajo y muchos más.

¿QUÉ ES UN SISTEMA DE GESTIÓN?

El nivel de complejidad del sistema dependerá del contexto específico de cada organización. Para algunas organizaciones, especialmente las más pequeñas, puede significar simplemente tener un fuerte liderazgo del dueño del negocio, proporcionando una definición clara de lo que se espera de cada empleado y cómo el contribuir a los objetivos generales de la organización, sin necesidad de una documentación exhaustiva.



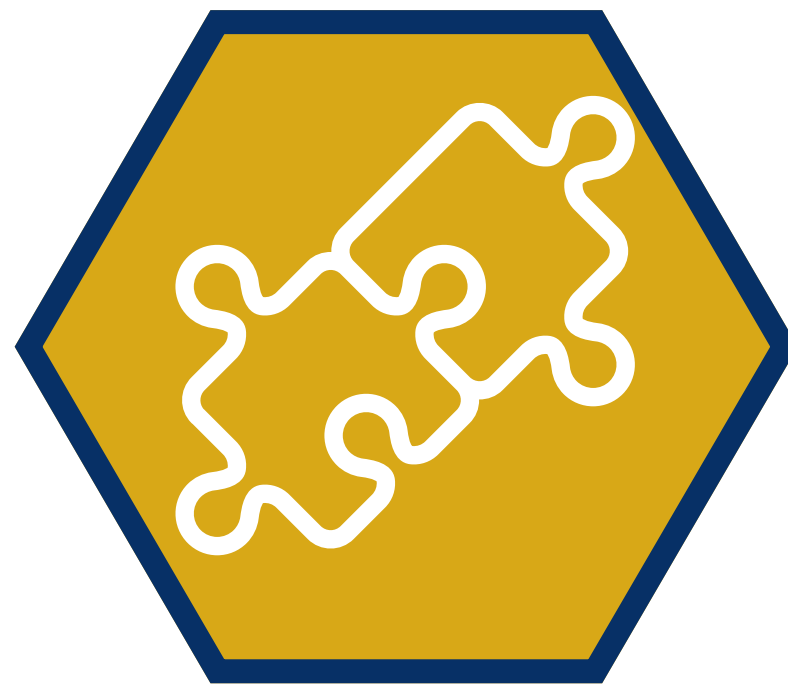
¿QUÉ ES UN SISTEMA DE GESTIÓN?

Las empresas más completas que operan, por ejemplo, en sectores altamente regulados, pueden necesitar una amplia documentación y controles para cumplir sus obligaciones legales y cumplir sus objetivos organizacionales.

¿CÓMO SE DEFINE LA SEGURIDAD DE LA INFORMACIÓN?



CONFIDENCIALIDAD



INTEGRIDAD



DISPONIBILIDAD

¿QUÉ ES UN SGSI (SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN)?

Un SGSI está compuesta por políticas, procedimientos, directrices, recursos y actividades asociadas, administrados colectivamente por una organización, con el fin de proteger sus activos de información.

Un SGSI es un enfoque sistemático para establecer, implementar, operar, monitorear, revisar, mantener y mejorar la seguridad de la información de una organización para lograr los objetivos comerciales.

¿QUÉ ES UN SGSI (SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN)?

Con base en una evaluación de riesgos y en los niveles de aceptación de riesgos de la organización diseñados para tratar y gestionar los riesgos de manera efectiva. El análisis de los requisitos para la protección de los activos de información y la aplicación de controles apropiados para garantizar la protección de estos activos de información, según se requiera, contribuye a la implementación exitosa de un SGSI.

FAMILIA ISO/IEC 27000

- ISO/IEC 27000 – Términos y definiciones
- ISO/IEC 27001 – Los requerimientos del SGSI (Certificable)
- ISO/IEC 27002 – Implementación de controles
- ISO/IEC 27003 – Implementación del SGSI
- ISO/IEC 27004 – Medición del SGSI
- ISO/IEC 27005 – Análisis de riesgos
- ISO/IEC 27006 – Requerimientos para una entidad certificadora
- ISO/IEC 27007 – Guía para auditar el SGSI
- ISO/IEC 27008 – Guía para auditores
- ISO/IEC 27032 – Ciberseguridad



CONSIDERACIONES ESPECIALES

Los “DEBES” de la norma

- ¿Dónde y por qué comprar la norma?
- ¿Cómo funciona el proceso de certificación?
- ¿Se pueden certificar personas en ISO/IEC 27001?

CUMPLIMIENTO



1.- LEYES / DECRETOS / MANDATOS NACIONALES



2.- REGULACIONES / INSTITUCIONES



3.- NORMAS



4.- POLÍTICAS / LINEAMIENTOS



5.- PROCESOS/ GUÍAS / INSTRUCTIVOS



6.- BUENAS PRACTICAS



ESTRUCTURA GENERAL

04

CONTEXTO DE LA ORGANIZACIÓN

05

LIDERAZGO

06

PLANIFICACIÓN

07

SOPORTE

08

OPERACIÓN

09

EVALUACIÓN DE DESEMPEÑO

10

MEJORA

ESTRUCTURA GENERAL

A05

CONTROLES ORGANIZACIONALES

A06

CONTROL DE PERSONAS

A07

CONTROLES FÍSICOS

A08

CONTROLES TECNOLÓGICOS

CAPÍTULO 4

Contexto de la organización



4.1 COMPRENDER LA ORGANIZACIÓN Y SU CONTEXTO

INTERNOS

La organización debe determinar los aspectos internos y externos que son relevantes para su propósito y que afectan su capacidad para lograr el o los resultado(s) deseado(s) de su sistema de gestión de seguridad de la información.

- Clima laboral
- Incidentes de seguridad ocurridos
- Nivel de concientización sobre seguridad de la información

EXTERNOS

- Tendencias tecnologías
- Incidentes de seguridad ocurridos en el país y en el mundo
- Identificar si la competencia ya cuenta con alineación con este tipo de normas

4.2 ENTENDIMIENTO DE LAS NECESIDADES Y EXPECTATIVAS DE LAS PARTES INTERESADAS.

La organización debe determinar:

- a) las partes interesadas que son relevantes al sistema de gestión de seguridad de la información, y;
- b) los requisitos de estas partes interesadas relevantes a la seguridad de la información.
- c) cuáles de estos requisitos se abordan a través del sistema de gestión de seguridad de información

Nota: Los requisitos de las partes interesadas pueden incluir los requisitos legales y reglamentarios y la seguridad de la información.

4.3 DETERMINAR EL ALCANCE DEL SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN.

La organización debe determinar los límites y la aplicabilidad del sistema de gestión de seguridad de la información para establecer su alcance.

Al determinar el alcance, la organización debe considerar:

- a) los aspectos externos e internos referidos en el 4.1;
- b) los requisitos referidos en el 4.2; Y
- c) las interfaces y las dependencias entre las actividades realizadas por la organización, y las que se realizan por otras organizaciones.

El alcance debe estar disponible como información documentada.

4.4 SISTEMA DE GESTIÓN DE LA SEGURIDAD DE INFORMACIÓN

La organización debe establecer, implementar, mantener y mejorar continuamente un sistema de gestión de seguridad de la información, incluyendo los procesos necesarios y sus interacciones, de acuerdo con los requisitos de este Proyecto de Norma Mexicana.

CAPÍTULO 5

Liderazgo



5.1 COMPROMISO Y LIDERAZGO

La alta dirección debe demostrar su liderazgo y compromiso con respecto al sistema de gestión de seguridad de la información a través de:

- a) garantizar que la política de seguridad de la información y los objetivos de seguridad de la información estén establecidos y sean compatibles con la dirección estratégica de la organización;
- b) garantizar la integración de los requisitos del sistema de gestión de seguridad de la información en los procesos de la organización;
- c) garantizar que los recursos necesarios para el sistema de gestión de seguridad de la información estén disponibles;
- d) comunicar la importancia de la gestión eficaz de la seguridad de la información y de la conformidad con los requisitos del sistema de gestión de seguridad de la información;

5.1 COMPROMISO Y LIDERAZGO

- e) garantizar que el sistema de gestión de seguridad de la información obtenga los resultados previstos;
- f) apoyar y dar dirección a las personas para contribuir a la eficacia del sistema de gestión de seguridad de la información;
- g) promover la mejora continua y;
- h) apoyar otros roles de gestión relevantes para demostrar su liderazgo, y compromiso conforme aplique a sus áreas de responsabilidad.

Nota: La referencia a “negocio” en este Proyecto de Norma Mexicana puede interpretarse en sentido amplio para referirse a aquellas actividades que son fundamentales para los propósitos de la existencia de la organización

5.2 POLÍTICA

La alta dirección debe establecer una política de seguridad de la información que:

- a) sea apropiada al propósito de la organización;
- b) incluya objetivos de seguridad de la información o proporcione el marco de trabajo para establecer los objetivos de seguridad de la información;
- c) incluya un compromiso para satisfacer los requisitos aplicables relacionados con la seguridad de la información, y;
- d) incluya el compromiso de mejora continua del sistema de gestión de seguridad de la información.

La política de seguridad de la información debe:

- e) estar disponible como información documentada;
- f) ser comunicada dentro de la organización, y;
- g) estar disponible a las partes interesadas en forma apropiada.

5.2 POLÍTICA

La alta dirección debe establecer una política de seguridad de la información que:

- a) sea apropiada al propósito de la organización;
- b) incluya objetivos de seguridad de la información o proporcione el marco de trabajo para establecer los objetivos de seguridad de la información;
- c) incluya un compromiso para satisfacer los requisitos aplicables relacionados con la seguridad de la información, y;
- d) incluya el compromiso de mejora continua del sistema de gestión de seguridad de la información.

La política de seguridad de la información debe:

- e) estar disponible como información documentada;
- f) ser comunicada dentro de la organización, y;
- g) estar disponible a las partes interesadas en forma apropiada.

5.3 ROLES ORGANIZACIONALES, RESPONSABILIDADES Y AUTORIDADES

La alta dirección debe asegurarse de que las responsabilidades y autoridades para los roles relevantes a la seguridad de la información se asignen y sean comunicadas dentro de la organización.

La alta dirección debe asignar la responsabilidad y autoridad para:

- a) garantizar que el sistema de gestión de seguridad de la información sea conforme a los requisitos de esta norma, e;
- b) informar sobre el desempeño del sistema de gestión de seguridad de la información a la alta dirección.

Nota: La alta dirección también puede asignar responsabilidades y autoridad para informar sobre el desempeño del Sistema de Gestión de Seguridad de la Información dentro de la organización

CAPÍTULO 6

Planeación



6.1.1 GENERALIDADES

Cuando se planee el Sistema de Gestión de Seguridad de la Información, la organización debe considerar los aspectos referidos en el inciso 4.1 y los requisitos referidos en el inciso 4.2 y determinar los riesgos y oportunidades que necesitan ser dirigidas para:

- a) asegurar que el sistema de gestión de seguridad de la información puede lograr el o los resultado(s) previsto(s);
- b) prevenir, o reducir, los efectos no deseados, y;
- c) lograr la mejora continua.

La organización debe planear:

- d) acciones para dirigir estos riesgos y oportunidades, y;
- e) a) Como;
 - 1) integrar e implementar las acciones en sus procesos del sistema de gestión de seguridad de la información, y;
 - 2) evaluar la eficacia de estas acciones.

6.1.2 VALORACIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

La organización debe definir y aplicar un **proceso** de valoración de riesgos de seguridad de la información para:

a) establecer y mantener los criterios de riesgos de seguridad de la información que incluya:

1) el criterio de aceptación del riesgo, y

2) los criterios para realizar las valoraciones de riesgos de seguridad de la información;

b) asegurar de que al repetir las valoraciones de riesgos de seguridad de la información produzcan resultados consistentes, válidos y comparables;

c) identificar los riesgos de seguridad de la información:

1) aplicar el proceso de valoración de riesgos de seguridad de la información para identificar los riesgos asociados a la pérdida de confidencialidad, integridad y disponibilidad de la información dentro del alcance del sistema de gestión de seguridad de la información, e

2) identificar a los propietarios de los riesgos

6.1.2 VALORACIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

- d) analizar los riesgos de seguridad de la información:
 - 1) valorar las consecuencias potenciales que se derivan si los riesgos identificados en el inciso 6.1.2 c) 1) llegan a materializarse;
 - 2) valorar la probabilidad realista de la ocurrencia de los riesgos identificados en el inciso 6.1.2 c) 1); y
 - 3) determinar los niveles de riesgo;
- e) evaluar los riesgos de seguridad de la información:
 - 1) comparar los resultados de análisis de riesgos con los criterios de riesgo establecidos en el inciso 6.1.2 a);
 - 2) priorizar los riesgos analizados para el tratamiento del riesgo.

La organización debe conservar información documentada sobre el proceso de valoración de riesgos de seguridad de la información.



Vulnerabilidad

Es una debilidad que puede ser aprovechada por una amenaza.

Amenaza

- Es un peligro potencial.
- Causa potencial de un incidente no deseado, que puede resultar en un daño a un sistema u organización.

Riesgo

- Es la probabilidad y/o posibilidad de que una amenaza explote una vulnerabilidad.
- Desviación de efectos esperados (Positivos o negativos)

Control/Contramedida/Salvaguarda

Modificador del riesgo --
Riesgo residual

No repudio

Es el mecanismo para corroborar que algo se llevó a cabo o no.

6.1.3 TRATAMIENTO DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

La organización debe definir y aplicar un proceso de tratamiento de los riesgos de seguridad de la información para:

- a) seleccionar opciones apropiadas de tratamiento de riesgos de seguridad de la información tomando en cuenta los resultados de la valoración de riesgos;
- b) determinar todos los controles que sean necesarios para implementar la(s) opción(es) de tratamiento de riesgos de seguridad de la información elegida(s);

NOTA Las organizaciones pueden diseñar controles según sea necesario, o identificarlos de cualquier fuente.

- c) comparar los controles determinados en el inciso 6.1.3 b), con los descritos en el apéndice "A" y verificar que no se hayan omitido controles necesarios;

NOTA 1 El apéndice "A" contiene una lista amplia de objetivos de control y controles. Los usuarios de esta norma son referidos al apéndice "A" para garantizar que no se pasen por alto los controles necesarios.

NOTA 2 Los objetivos de control se incluyen implícitamente en los controles seleccionados. Los objetivos de control y controles listados en el apéndice "A" no son exhaustivos y pueden ser necesarios objetivos de control y controles adicionales.

6.1.3 TRATAMIENTO DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

- d) elaborar una Declaración de aplicabilidad que contenga los controles necesarios (véase el inciso 6.1.3 b) y c)) y la justificación de las inclusiones, si están implementadas o no, y la justificación de la exclusión de controles del apéndice “A”;
- e) formular un plan de tratamiento de riesgos de seguridad de la información, y
- f) obtener la aprobación del plan de tratamiento de riesgos de seguridad de la información y aceptación de los riesgos residuales de seguridad de la información por parte de los propietarios de los riesgos.

La organización debe conservar información documentada sobre el proceso de tratamiento de riesgos de seguridad de la información

Nota: El proceso de valoración y tratamiento de riesgos de seguridad de la información en este Proyecto de Norma Mexicana se alinea con los principios y lineamientos genéricos previstos en la NMX-SAST-31000- IMNC-2018.

METODOLOGÍAS DE ANÁLISIS DE RIESGOS

ISO/IEC 27005:2018

ISO 31000:2018

COBIT 5 for risk

NIST-SP 800-30 Rev 1

NIST-SP 800-39

NIST-SP 800-37 Rev 1

OCTAVE

MAGERIT

6.2 ALCANZANDO LOS OBJETIVOS Y PLANES DE SEGURIDAD DE LA INFORMACIÓN

La organización debe establecer los objetivos de seguridad de la información en funciones y niveles pertinentes.

Los objetivos de seguridad de la información deben:

- a) ser consistentes con la política de seguridad de la información;
- b) ser medibles (si es práctico);
- c) tener en cuenta los requisitos de seguridad de la información aplicables, y los resultados de la valoración del riesgo y el tratamiento del riesgo;
- d) ser monitoreados;
- e) ser comunicados; y
- f) estar actualizados según corresponda
- g) estar disponibles como información documentada.

6.2 ALCANZANDO LOS OBJETIVOS Y PLANES DE SEGURIDAD DE LA INFORMACIÓN

La organización debe conservar información documentada sobre los objetivos de seguridad de la información.

Cuando se planee cómo alcanzar sus objetivos de seguridad de la información, la organización debe determinar:

- h) qué se va hacer;
- i) qué recursos son requeridos ;
- j) quién es responsable;
- k) cuándo se va a terminar; y
- l) cómo se evalúan los resultados.

6.3 PLANIFICACIÓN DE CAMBIOS

Cuando la organización determine como necesarios cambios en el sistema de gestión de seguridad de la información, estos cambios deben llevarse a cabo de planificada

CAPÍTULO 7

Soporte





7.1 RECURSOS

La organización debe determinar y proveer los recursos necesarios para el establecimiento, implementación, mantenimiento y mejora continua del sistema de gestión de seguridad de la información.

7.2 COMPETENCIA

La organización debe:

- a) determinar la competencia necesaria del personal que hace el trabajo bajo su control que afecte el desempeño de seguridad de la información;
- b) asegurar que estas personas sean competentes con base a una educación, capacitación o experiencia apropiada;
- c) cuando sea necesario, tomar acciones para adquirir las competencias necesarias, y evaluar la eficacia de las acciones tomadas, y;
- d) conservar la información documentada apropiada como prueba de competencia.

NOTA Las acciones aplicables pueden incluir, por ejemplo, la provisión de capacitación, tutoría, o reasignación de los empleados actuales, o la contratación de personas competentes.

7.3 CONCIENTIZACIÓN

Las personas que realizan trabajos bajo el control de la organización deben ser conscientes de:

- a) la política de seguridad de la información;
- b) su contribución a la eficacia del sistema de gestión de seguridad de la información, incluyendo los beneficios de un mejor desempeño de seguridad de la información, y
- c) las implicaciones de no cumplir con los requisitos del sistema de gestión de seguridad de la información.

7.4 COMUNICACIÓN

La organización debe determinar la necesidad de las comunicaciones internas y externas relacionadas con el sistema de gestión de seguridad de la información, incluyendo:

- a) sobre qué comunicar;
- b) cuándo comunicar;
- c) a quien comunicar;
- d) quien debe comunicar

CAPÍTULO 7.5

Información documentada



7.5.1 GENERALIDADES

El sistema de gestión de seguridad de la información debe incluir:

- a) información documentada requerida por esta norma, e
- b) información documentada determinada por la organización como sea necesario para la eficacia del sistema de gestión de seguridad de la información

NOTA La extensión de la información documentada para un sistema de gestión de seguridad de la información puede diferir de una organización a otra debido a:

- a) el tamaño de la organización y el tipo de actividades, procesos, productos y servicios;
- b) la complejidad de los procesos y sus interacciones, y
- c) la competencia de las personas.

7.5.2. CREACIÓN Y ACTUALIZACIÓN

Al crear y actualizar la información documentada de su apropiada:

- a) identificación y descripción (por ejemplo, un título, fecha, autor, o el número de referencia);
- b) formato (por ejemplo, el idioma, la versión de software, gráficos) y los medios (por ejemplo, papel, electrónico), y
- c) revisión y aprobación de la idoneidad y adecuación.

7.5.3 CONTROL DE LA INFORMACIÓN DOCUMENTADA

La información documentada requerida por el Sistema de Gestión de Seguridad de la Información y por este Proyecto de Norma Mexicana debe ser controlada para asegurar:

- a) que esté disponible y adecuada para su uso, donde y cuando sea necesario, y
- b) que sea protegida adecuadamente (por ejemplo, de la pérdida de confidencialidad, uso indebido, o la pérdida de la integridad).

Para el control de la información documentada, la organización debe realizar las siguientes actividades, según corresponda:

- c) la distribución, acceso, recuperación y uso;
- d) almacenamiento y preservación , incluyendo la preservación de la legibilidad;
- e) el control de cambios (por ejemplo, control de versiones), y
- f) la retención y disposición.

7.5.3 CONTROL DE LA INFORMACIÓN DOCUMENTADA

La información documentada de origen externo, que la organización determine que son necesarios para la planeación y operación del sistema de gestión de seguridad de la información, debe identificarse y controlarse apropiadamente.

NOTA El acceso implica una decisión sobre el permiso de ver sólo la información documentada, o el permiso y la autoridad para ver y cambiar la información documentada, etc.

CAPÍTULO 8

Operación



8.1 CONTROL Y PLANEACIÓN OPERACIONAL

La organización debe planificar, implementar y controlar los procesos necesarios para cumplir con los requisitos e implementar las acciones determinadas en el capítulo 6 a través de:

- a) establecer criterios para los procesos;
- b) implementar el control de los procesos de acuerdo con los criterios.

La información documentada debe estar disponible en la medida necesaria para tener confianza en que los procesos se han llevado a cabo según lo planeado.

8.1 CONTROL Y PLANEACIÓN OPERACIONAL

La organización debe controlar los cambios planificados y revisar las consecuencias de los cambios no deseados, tomando medidas para mitigar cualquier efecto adverso, según sea necesario.

La organización debe garantizar que los procesos, productos o servicios proporcionados externamente que sean relevantes para el sistema de gestión de la seguridad de la información estén controlados.



8.2 EVALUACIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

- La organización debe llevar a cabo las valoraciones de riesgos de seguridad de la información a intervalos planificados o cuando se proponen o se producen cambios significativos, teniendo en cuenta los criterios establecidos en el inciso 6.1.2 a).
- La organización debe conservar la información documentada de los resultados de las valoraciones de riesgos de seguridad de la información.

8.3 TRATAMIENTO DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

- La organización debe implementar el plan de tratamiento de riesgos de seguridad de la información.
- La organización debe conservar la información documentada de los resultados del tratamiento de riesgos de seguridad de la información.

CAPÍTULO 9

La evaluación del desempeño



9.1 MONITOREO, MEDICIÓN, ANÁLISIS Y EVALUACIÓN

La organización debe determinar:

- a) que necesita ser monitoreado y medido, incluyendo los procesos y los controles de seguridad de la información;
- b) los métodos de monitoreo, medición, análisis y evaluación son necesarios para garantizar los resultados válidos. Los métodos seleccionados deben producir resultados comparables y reproducibles para que se consideren válidos.
- c) Cuando debe llevarse a cabo el monitoreo y medición;
- d) ¿Quién debe monitorear y medir?;
- e) Cuando los resultados del monitoreo y medición deben ser analizados y evaluados; y
- f) ¿Quién debe analizar y evaluar los resultados?

La información documentada deberá estar disponible como evidencia de los resultados.

La organización debe evaluar el desempeño de la seguridad de la información y la eficacia del Sistema de Gestión de Seguridad de la Información.

TIPOS DE AUDITORIA

- Auditoria de primera parte
- Auditoria de segunda parte
- Auditoria de tercera parte

METODOLOGÍAS Y CERTIFICACIONES

- CISA
- ISO 19011
- ISO 17021
- Modelo COSO

9.2 AUDITORÍA INTERNA

9.2.1 General

La organización debe realizar auditorías internas a intervalos planificados para proporcionar información sobre si el Sistema de Gestión de Seguridad de la Información:

a) se ajusta a:

- 1) los requisitos propios de la organización para su Sistema de Gestión de Seguridad de la Información;
- 2) los requisitos de la norma;

b) se implementa y mantiene de manera efectivamente.

9.2.2 PROGRAMA DE AUDITORÍA INTERNA

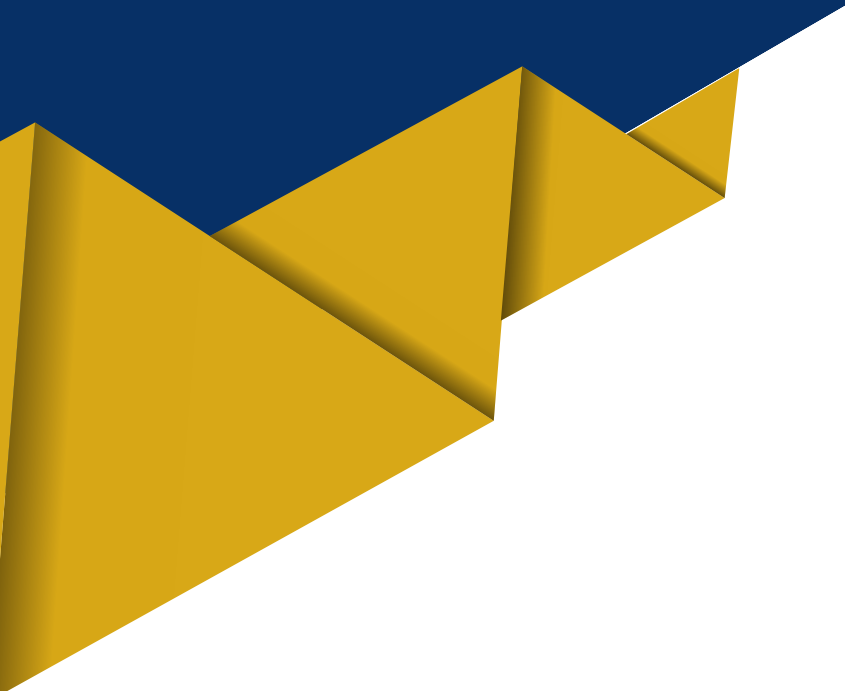
La organización debe planificar, establecer, implementar y mantener uno o varios programas de auditoría, incluyendo la frecuencia, los métodos, las responsabilidades, los requisitos de planificación y la elaboración de informes.

Al establecer los programas de auditoría interna, la organización debe considerar la importancia de los procesos en cuestión y los resultados de auditorías anteriores.

La organización deberá:

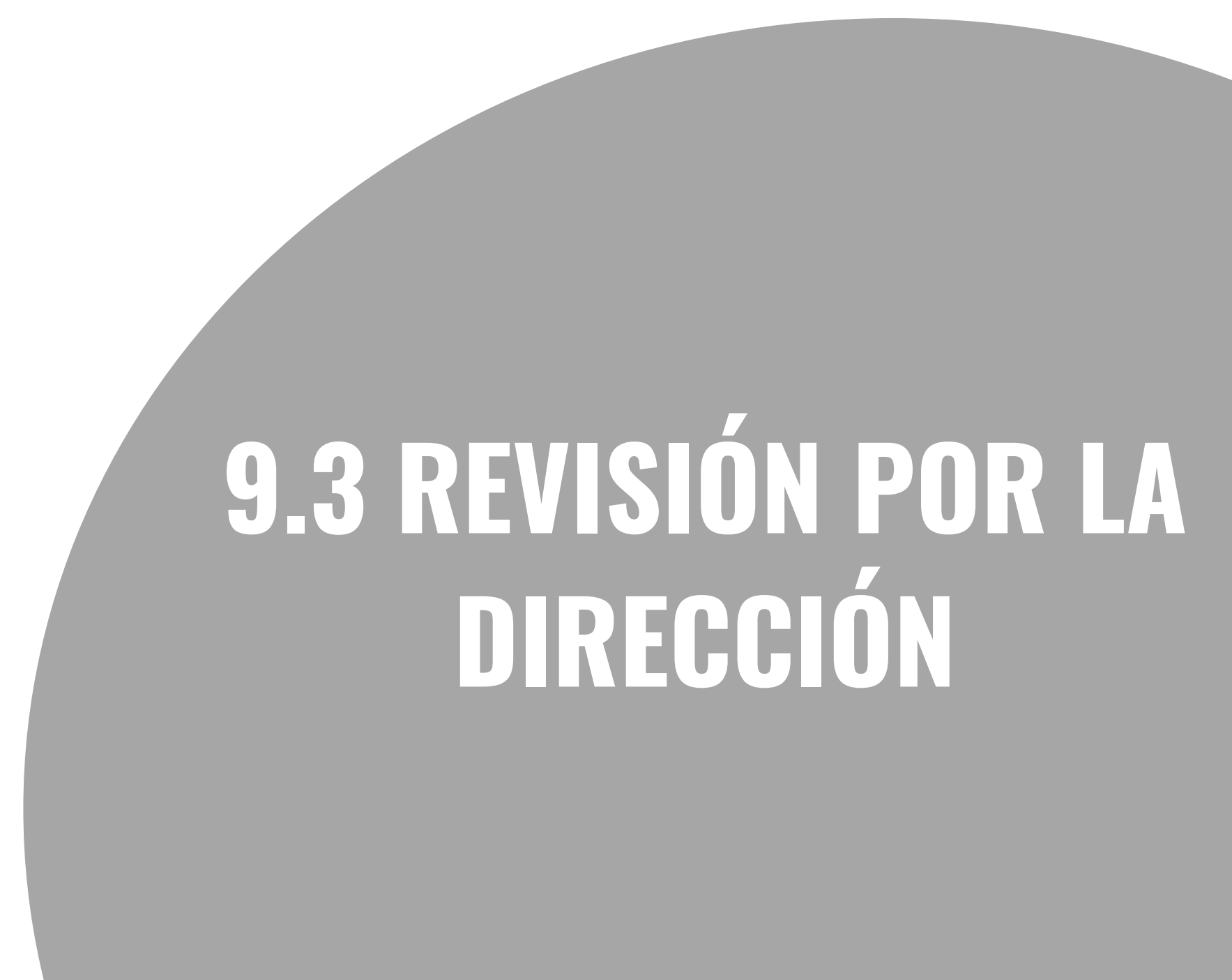
- a) definir los criterios de auditoría y el alcance de cada auditoría;
- b) seleccionar auditores y realizar auditorías que garanticen la objetividad y la imparcialidad del proceso de auditoría;
- c) asegurarse de que los resultados de las auditorías se informen a la dirección pertinente.

La información documentada deberá estar disponible como evidencia de la implementación del programa(s) de auditoría y los resultados de la auditoría.



9.3.1 GENERAL

La alta dirección debe revisar el Sistema de Gestión de Seguridad de la Información de la organización, a intervalos planeados para asegurar su continuad, vigencia, adecuación y eficacia.



9.3 REVISIÓN POR LA DIRECCIÓN

9.3.2 INSUMOS PARA LA REVISIÓN POR LA DIRECCIÓN

La revisión por la dirección debe incluir la consideración de:

- a) El estatus de las acciones previas de las revisiones por la
- .b) Los cambios en temas externos e internos que son relevantes para el Sistema de Gestión de Seguridad de la Información;
- c) cambios en las necesidades y expectativas de las partes interesadas que son relevantes para el sistema de gestión de seguridad de la información
- d) los resultados retroalimentación sobre el desempeño de la seguridad de la información, incluyendo las tendencias en:
 - 1) No conformidades y acciones correctivas;
 - 2) Monitoreo y resultados de medición;
 - 3) Resultados de la auditoría; y
 - 4) Cumplimiento de los objetivos de seguridad de la información;
- e) Retroalimentación de las partes interesadas;
- f) Resultados de la valoración del riesgo y el estatus del plan de tratamiento de riesgo; y
- g) Las oportunidades para la mejora continua;



9.3.3 RESULTADOS DE LA REVISIÓN POR LA DIRECCIÓN

Los resultados de la revisión por la dirección deben incluir decisiones relacionadas con las oportunidades de mejora continua y cualquier necesidad de cambios en el sistema de gestión de la seguridad de la información. Los resultados de las revisiones por la dirección deben estar disponible como información documentada.

CAPÍTULO 10

Mejora





10.1 MEJORA CONTINUA

La organización debe mejorar continuamente la idoneidad, la adecuación y la eficacia del Sistema de Gestión de Seguridad de la Información.

10.2 NO CONFORMIDAD Y ACCIÓN CORRECTIVA

Cuando ocurre una no conformidad, la organización debe:

a) Reaccionar a una no conformidad, y según sea el caso:

1) Tomar acciones para controlarla y corregirla, y

2) Hacer frente a las consecuencias;

b) Evaluar la necesidad de acciones para eliminar las causas de la no conformidad, con el fin de que no se repita u ocurra en otro lugar, a través de:

1) Revisión de la no conformidad;

2) Determinar las causas de la no conformidad; y

3) Determinar si existen no conformidades similares o que potencialmente puedan ocurrir;

c) Implementar las acciones necesarias;

d) Revisar la eficacia de las medidas correctivas tomadas; y

e) Realizar cambios al Sistema de Gestión de Seguridad de la Información, si es necesario.

10.2 NO CONFORMIDAD Y ACCIÓN CORRECTIVA

Las acciones correctivas deben ser apropiadas a los efectos de las no conformidades encontradas.

La organización debe conservar información documentada como evidencia de:

- f) La naturaleza de las no conformidades y de cualquier acción tomada posteriormente; y
- g) Los resultados de cualquier acción correctiva.